Preventing Broken Access Control

- ◉ **The Frontend is not trusted:** data coming from the frontend cannot be trusted
- ✓ **The backend is the only trusted domain:** sensitive operations must be done on the backend
- ✓ **Deny by default:** Explicitly grant access only when authorized

- **Least privilege:** Grant users only the permissions they need
- **Server-side enforcement:** Never rely on client-side access controls
- **Check every request:** Validate authorization for every resource and operation
- **Secure sessions:** Protect tokens and properly invalidate sessions
- **Restrict CORS:** Allow only explicitly trusted origins
- **Test authorization:** Verify that users cannot access other users' resources or privileged functions

A02 - Security Misconfiguration

- **Problem:** Insecure configuration of applications, servers, or cloud services that introduces vulnerabilities
- **Impact:** Unauthorized access, data exposure, or system compromise

Common vulnerabilities:

- **Default credentials:** Unchanged passwords or accounts
- **Unnecessary features:** Exposed ports, services, or debugging tools
- **Insecure permissions:** Misconfigured cloud storage or access controls
- **Information leakage:** Verbose error messages or stack traces
- **Missing security settings:** Disabled protections or missing HTTP security headers
- **Outdated configurations:** Legacy or insecure settings retained after upgrades